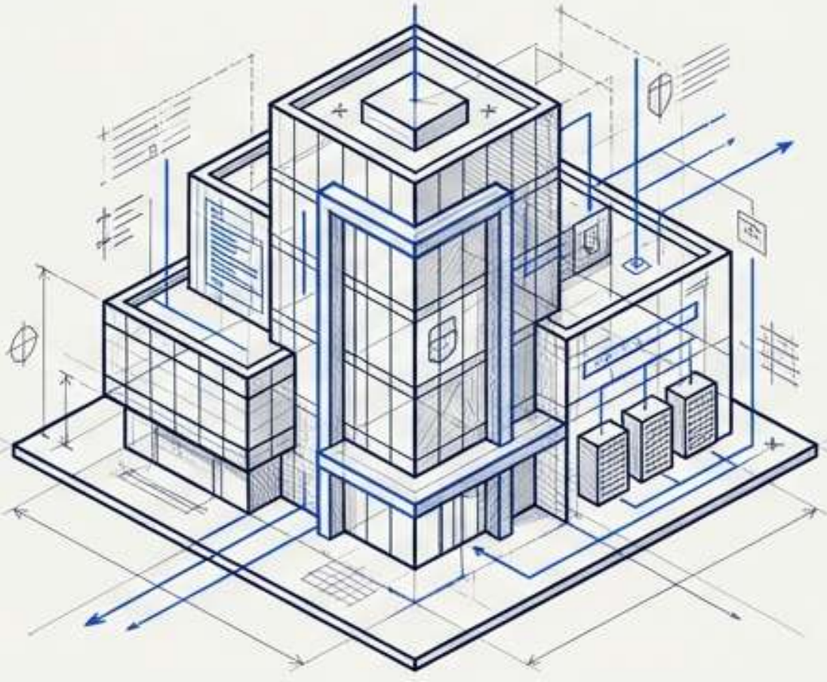
Progetto Architettonico di Sicurezza Informatica

Piano di Risanamento Strategico in 5 Fasi per TechnoSoft Srl

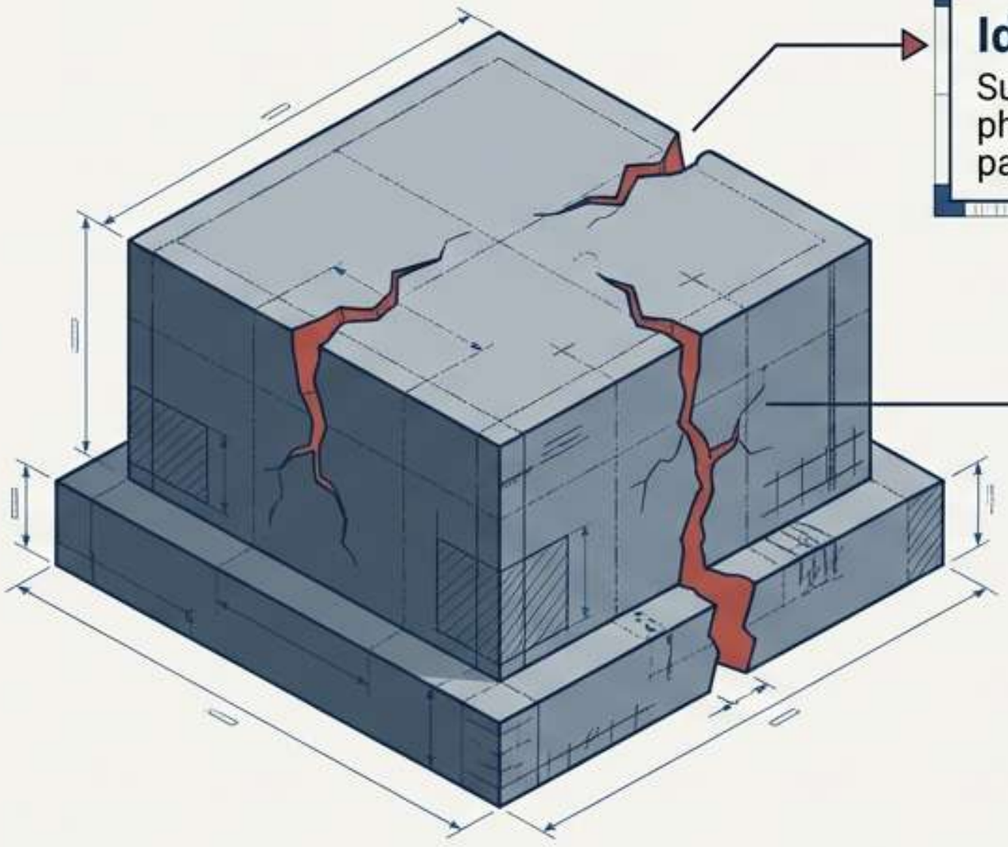
Dalle vulnerabilità dell'audit alla resilienza aziendale totale



PROJECT:	PROJECT:	DATE:	REV:
TECH-SEC-RENOVATION	TECH-SEC-RENOVATION	2024-10-27	A.01

NotebookLM

L'Esito dell'Audit: Fenditure Strutturali nel Perimetro



Identità Fragile

Successo degli attacchi di phishing e adozione di schemi di password prevedibili.

Rete Piatta

Assenza di segmentazione. Un'infezione nel reparto supporto può propagarsi liberamente ai server di sviluppo.

Crittografia Obsoleta

Utilizzo dello standard DES, forzabile in poche ore, esponendo il codice sorgente.

La tecnologia attuale non è in grado di contenere un attacco. Serve una ricostruzione architetturale.

NotebookLM

Il Progetto in 5 Fasi: Dalle Fondamenta al Tetto

Fase 5: Governance e Resilienza

Istruire le guardie con Formazione e BCDR.

Fase 4: Gestione Accessi

Controllare le porte tramite IAM e Privilege Management.

Fase 3: Protezione Dati

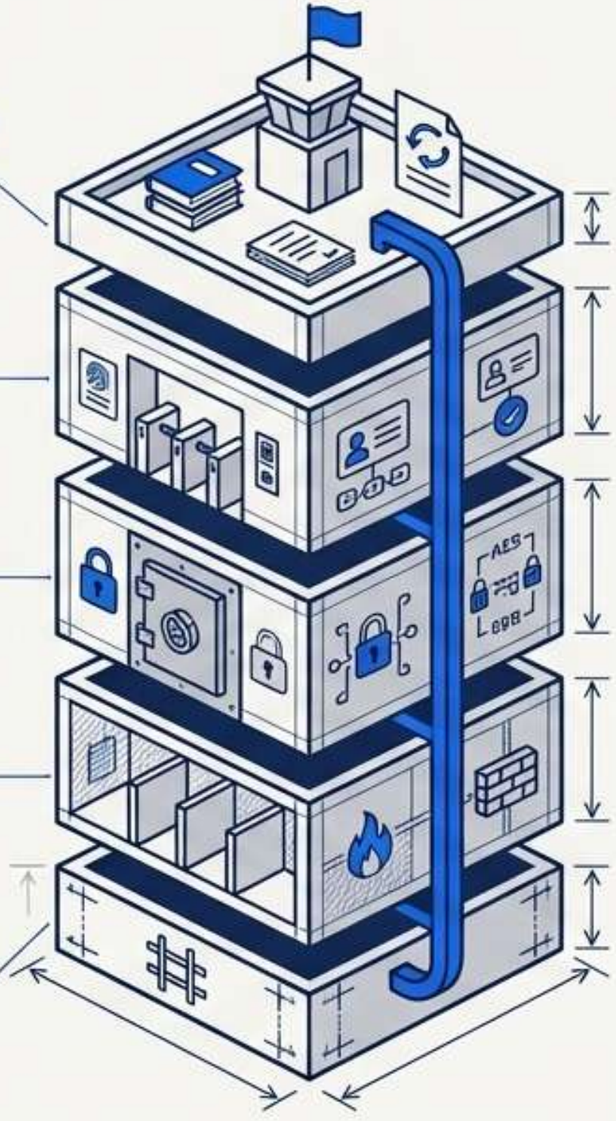
Blindare il caveau con AES-256 e MDM.

Fase 2: Sicurezza Rete

Erigere muri interni tramite VLAN e Firewall.

Fase 1: Risanamento Immediato

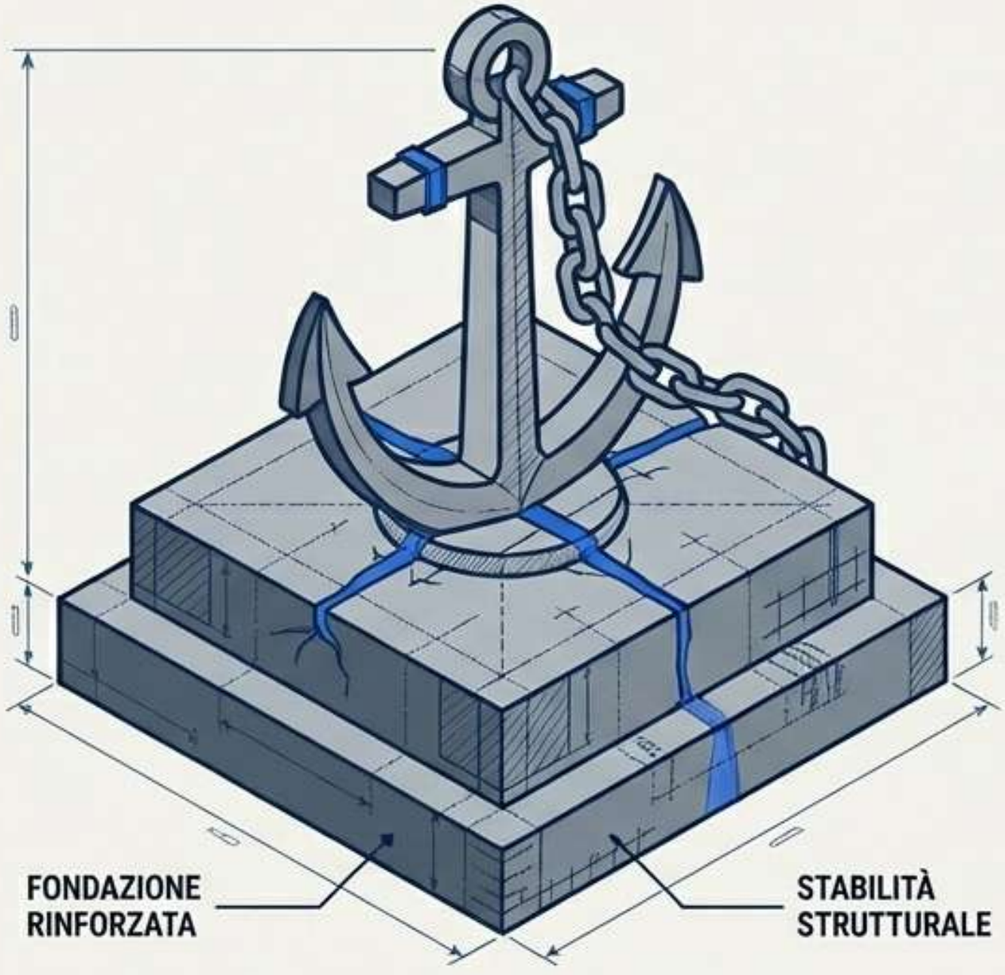
Stabilizzare le fondamenta con MFA ed EDR.



NotebookLM

Fase 1: Risanamento Immediato (Quick Wins)

Ottenere il massimo incremento di sicurezza con il minimo sforzo strutturale.
Ridurre drasticamente la capacità di movimento di un attaccante prima ancora di segmentare la rete.



MFA & Password Policy
Bloccare le identità compromesse

EDR (Endpoint Detection & Response)
Fermare il comportamento malevolo sui laptop

WAF (Web Application Firewall)
Patching virtuale per le app vulnerabili

NotebookLM

Selezione MFA: Difesa Attiva contro il Phishing

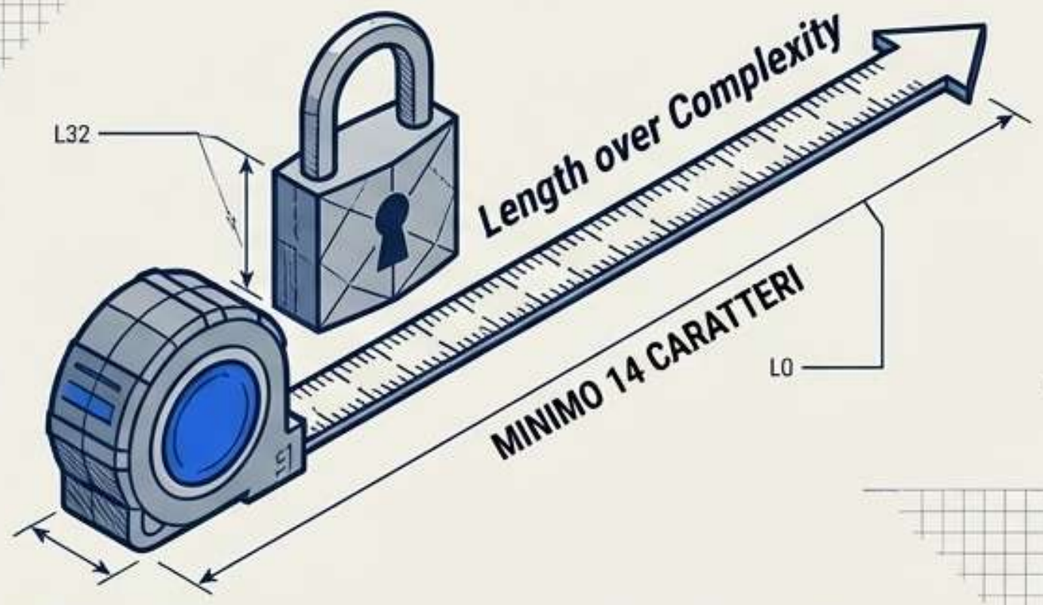
Feature	Cisco Duo (Scelta Raccomandata)	Microsoft Entra ID (Alternativa Strategica)	Okta
Resilienza Phishing	Notifiche Push trasparenti	Accesso Condizionale	Multi-cloud
Controllo Salute Dispositivo	Blocco OS obsoleti	Integrato in M365	Integrazione API
Velocità di Rollout	Giorni (nessun hardware extra)	Dipende da licenza	Complesso
Ecosistema Ideale	Rapido e Agnostico	Microsoft-centric	Ecosistemi frammentati

Regola Admin: Obbligo di **Passkey/FIDO2** (chiavi hardware fisiche come Yubikey) per gli amministratori, rendendo l'accesso virtualmente inhackerabile.

NotebookLM

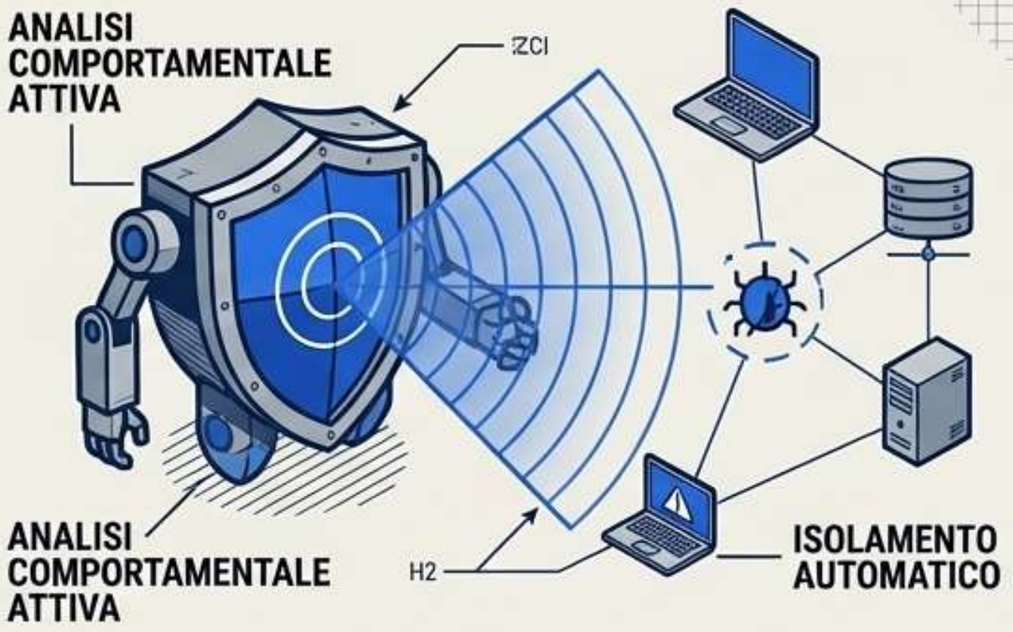
Modernizzare le policy: Identità ed Endpoint

La Nuova Regola Password



- **Transizione**: Lunghezza > Complessità.
- Minimo 14 caratteri.
- **Filtro** attivo contro le password compromesse (es. Password123!).
- **Stop** ai reset periodici obbligatori: basta con pattern prevedibili (es. Primavera2026!).

Dal vecchio Antivirus all'EDR



- L'antivirus tradizionale cerca solo firme note.
- L'**EDR** monitora il comportamento attivo.
- **Azione automatica**: Se un laptop lancia script insoliti o cripta file, l'EDR lo isola istantaneamente dalla rete.

NotebookLM

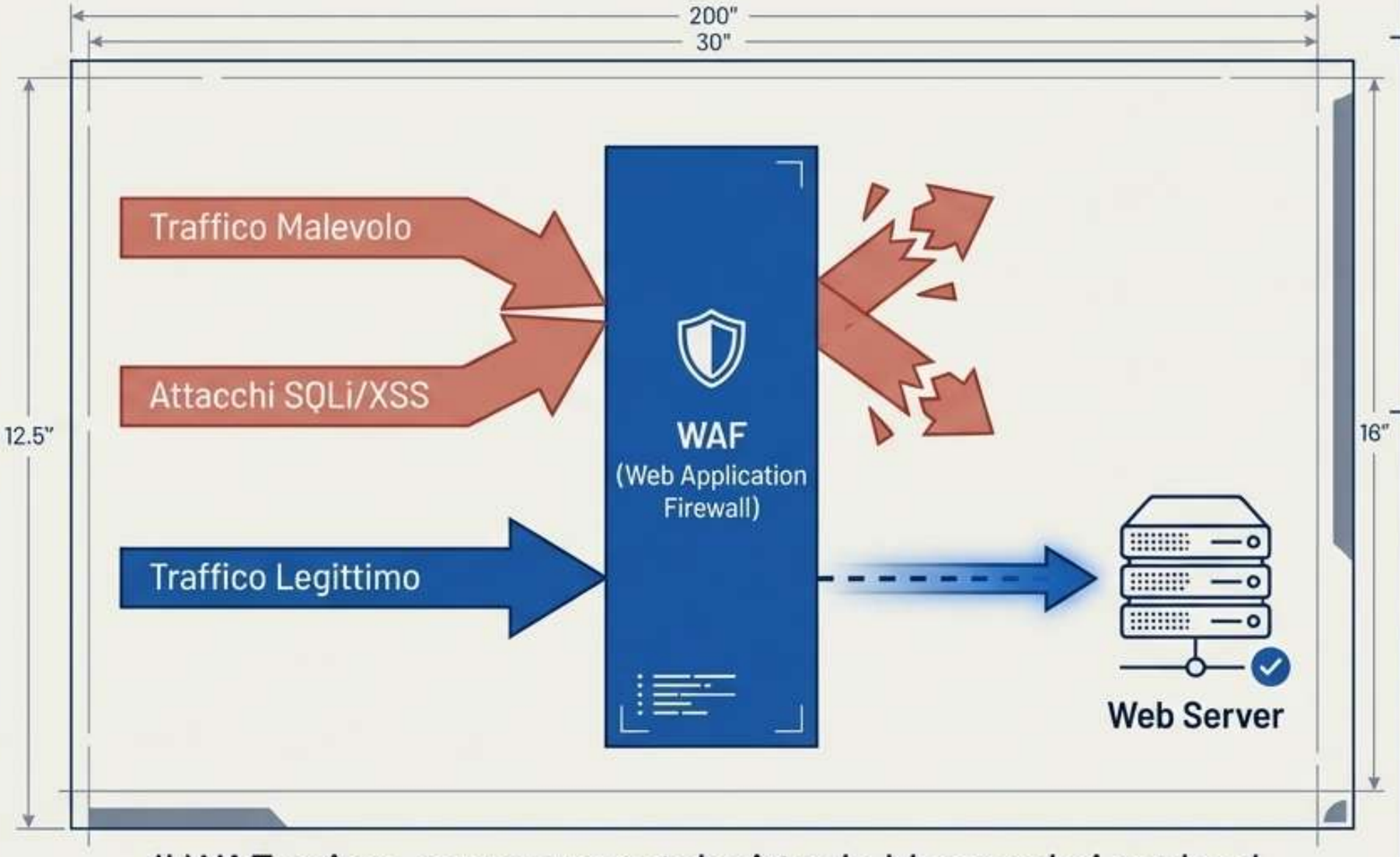
Virtual Patching: La Rete di Sicurezza per le Applicazioni

Il Problema:

Vulnerabilità critiche (SQL Injection, XSS) identificate nel codice. Le patch manuali richiedono tempo.

La Soluzione:

Implementazione di un Web Application Firewall (WAF).

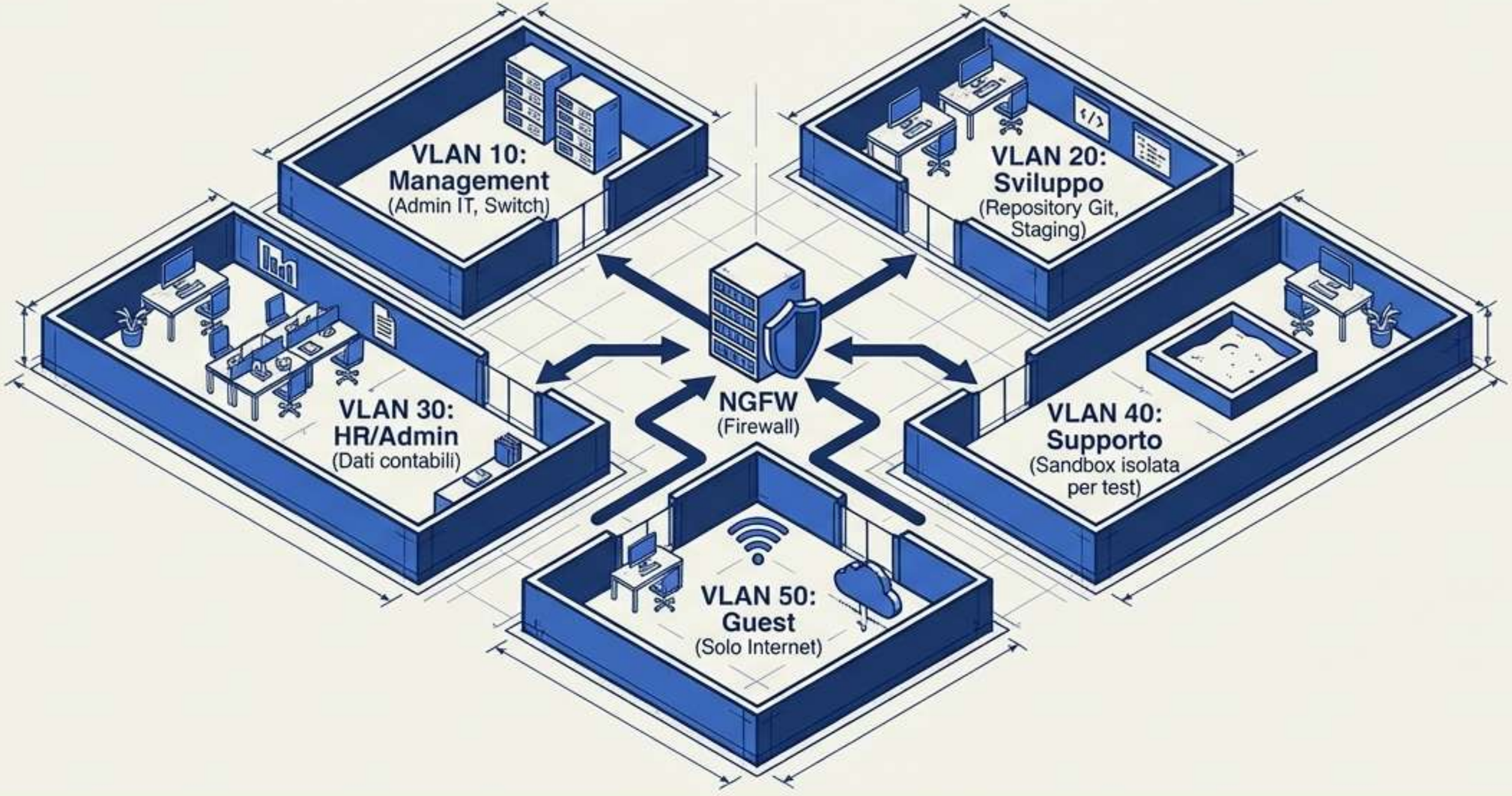


Il WAF agisce come una patch virtuale bloccando i payload malevoli prima che raggiungano il server.

NotebookLM

Fase 2: Muri Interni e Segmentazione (VLAN)

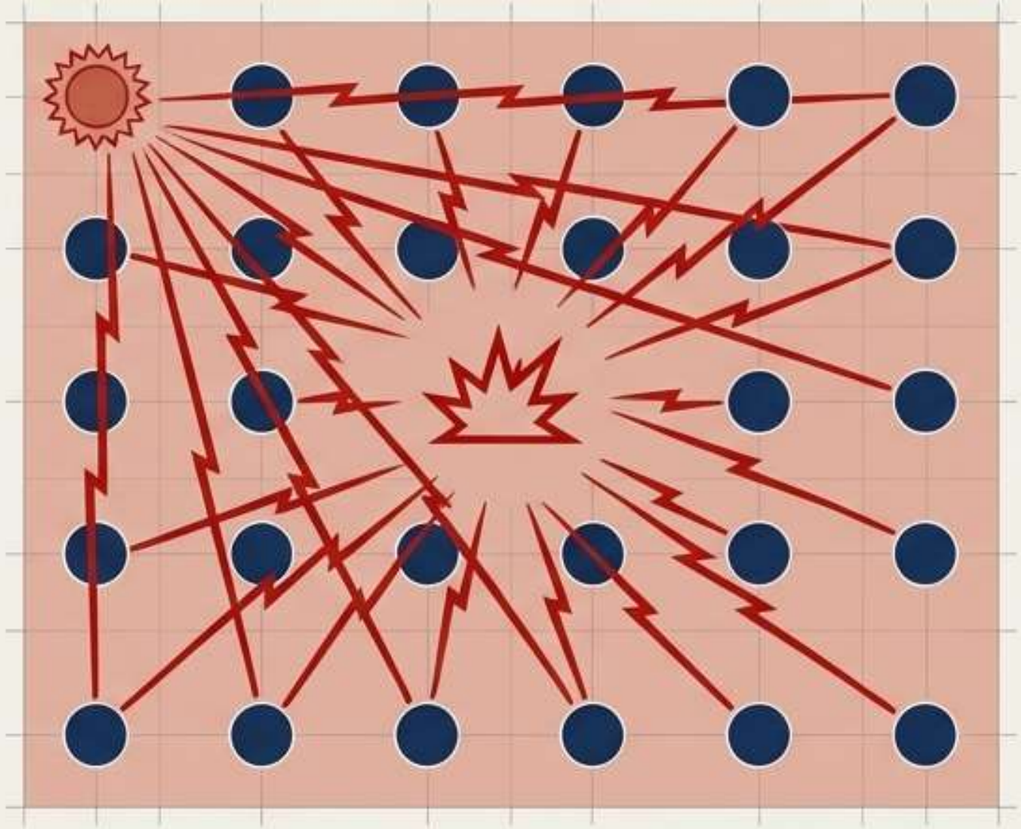
Eliminare la Rete Piatta. Dividere l'azienda in compartimenti stagni logici.



NotebookLM

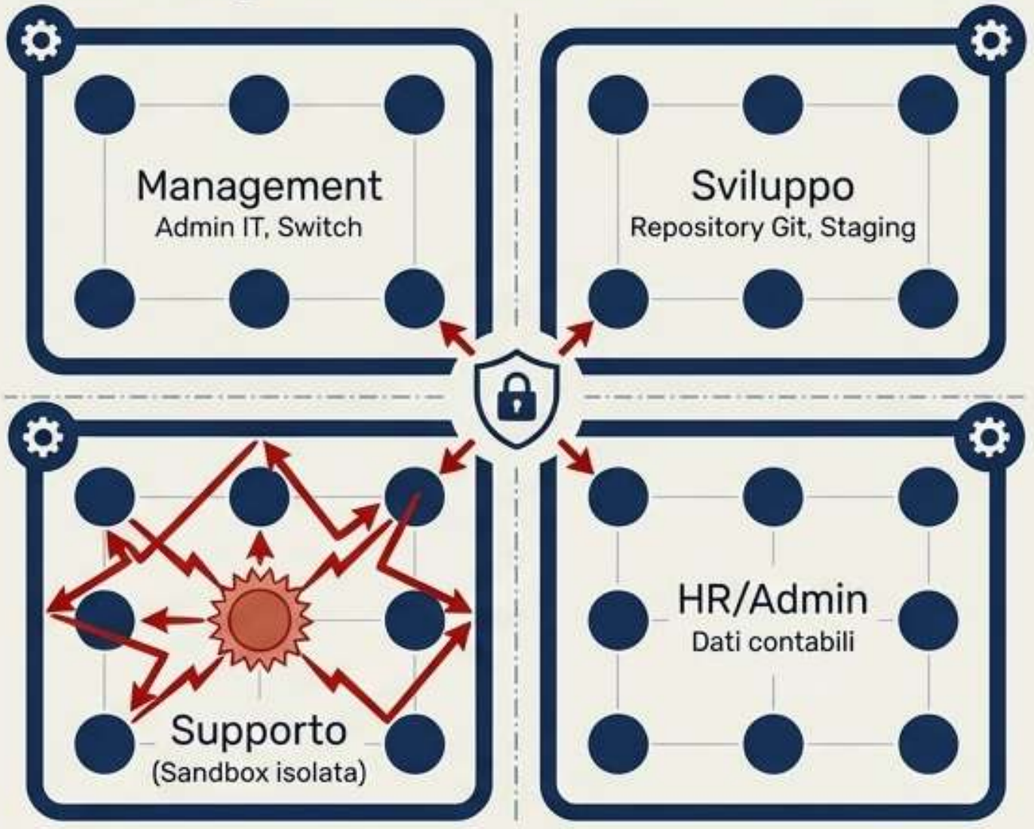
Il Principio di Contenimento: Ridurre il "Blast Radius"

Senza Segmentazione (Rete Piatta)



Un PC infetto nel reparto supporto compromette il codice sorgente e l'intera infrastruttura.

Con Segmentazione (VLAN + NGFW)



Il ransomware rimane intrappolato. Il Core Business è protetto fisicamente dal traffico laterale.

NotebookLM

Il Nuovo Perimetro: ZTNA e Ispezione Profonda

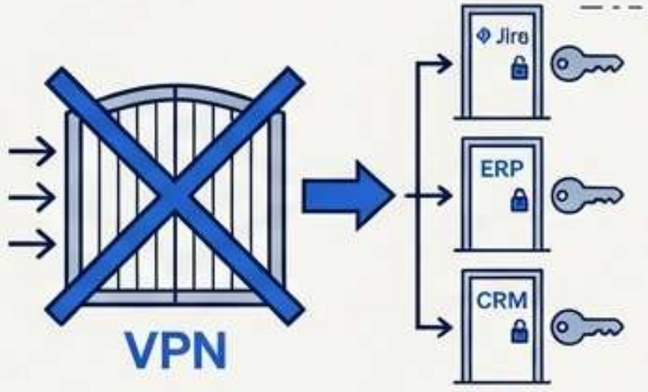
NGFW (Deep Packet Inspection)

Il firewall analizza non solo chi comunica, ma **cosa** dice. Blocca i malware in transito tra le VLAN.

Monitoraggio Attivo (IDS/IPS)

Rilevamento passivo (scansione porte) e **prevenzione** attiva tramite blocco delle connessioni in tempo reale.

Accesso Remoto: Da VPN a ZTNA



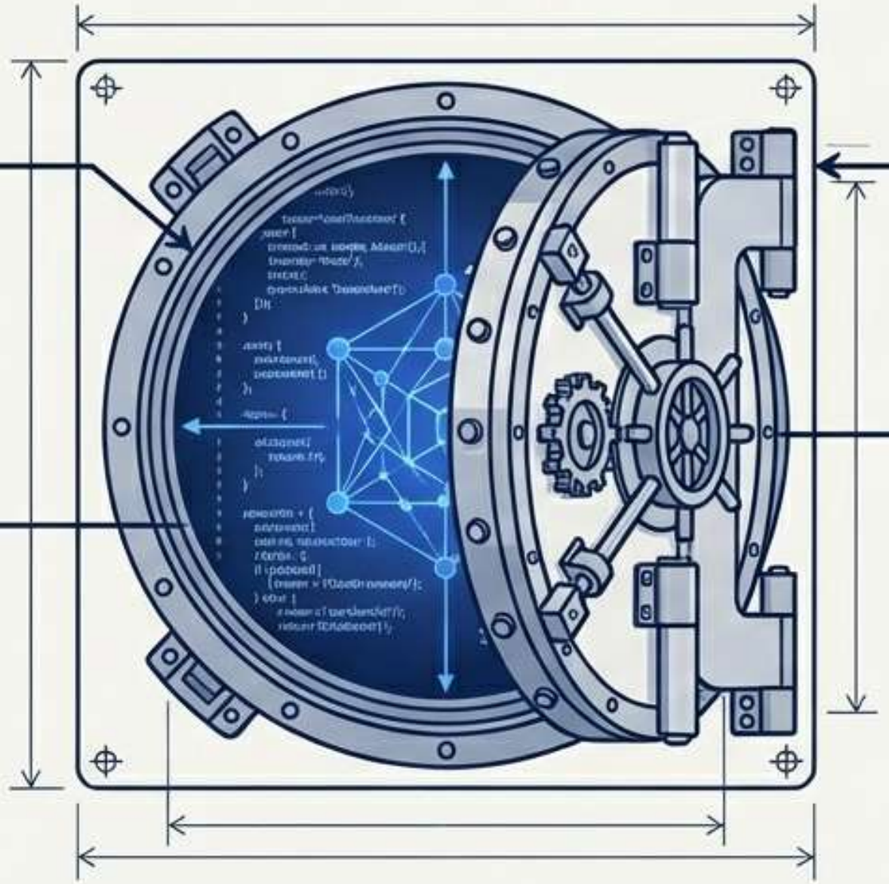
Evoluzione verso lo **Zero Trust**. Invece di accedere a tutta la rete, il consulente remoto vede solo la singola applicazione autorizzata (es. server Jira).

NotebookLM

Fase 3: Crittografia e Protezione Dati

Blindare le informazioni aziendali e i dati di terzi gestiti da TechnoSoft per garantire resilienza e conformità legale (GDPR).

Modernizzazione dei Protocolli
(Abbandono del DES)

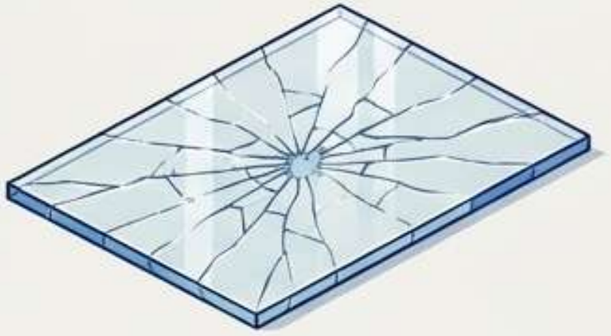


Protezione del "Tesoro"
(Codice Sorgente)

Controllo della Dispersione
(MDM e DLP)

NotebookLM

L’Upgrade Crittografico (Da DES ad AES-256)



Il Rischio: DES (Data Encryption Standard)

Standard obsoleto, forzabile in poche ore.

La Nuova Difesa: AES-256

Crittografia moderna universale.

Dati a Riposo (At Rest)

Adozione di AES-256 per tutti i database contenenti codice sorgente e dati clienti.

Dati in Transito (In Transit)

Implementazione di TLS 1.3. Disabilitazione immediata dei vecchi protocolli SSL e TLS 1.0/1.1.

Governance delle Chiavi (KMS)

Centralizzazione tramite Key Management Service. Le chiavi crittografiche non devono mai essere gestite localmente dagli sviluppatori.

NotebookLM

Proteggere il "Tesoro": Codice e Dispositivi

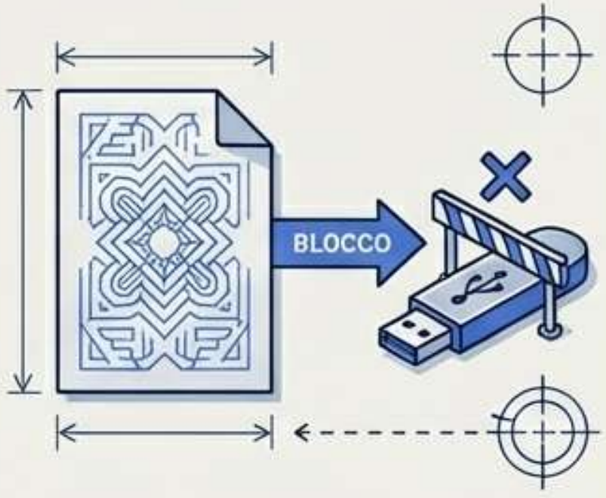
Integrità del Prodotto

Code Signing: Firma digitale di tutto il software rilasciato. Garantisce ai clienti l'assenza di manomissioni o inserimento malware post-sviluppo.

Endpoint Blindati

Gestione MDM: Utilizzo di Intune/Jamf per forzare la Full Disk Encryption (BitLocker/FileVault) sui 100 laptop. Capacità di Remote Wipe in caso di furto.

Data Loss Prevention

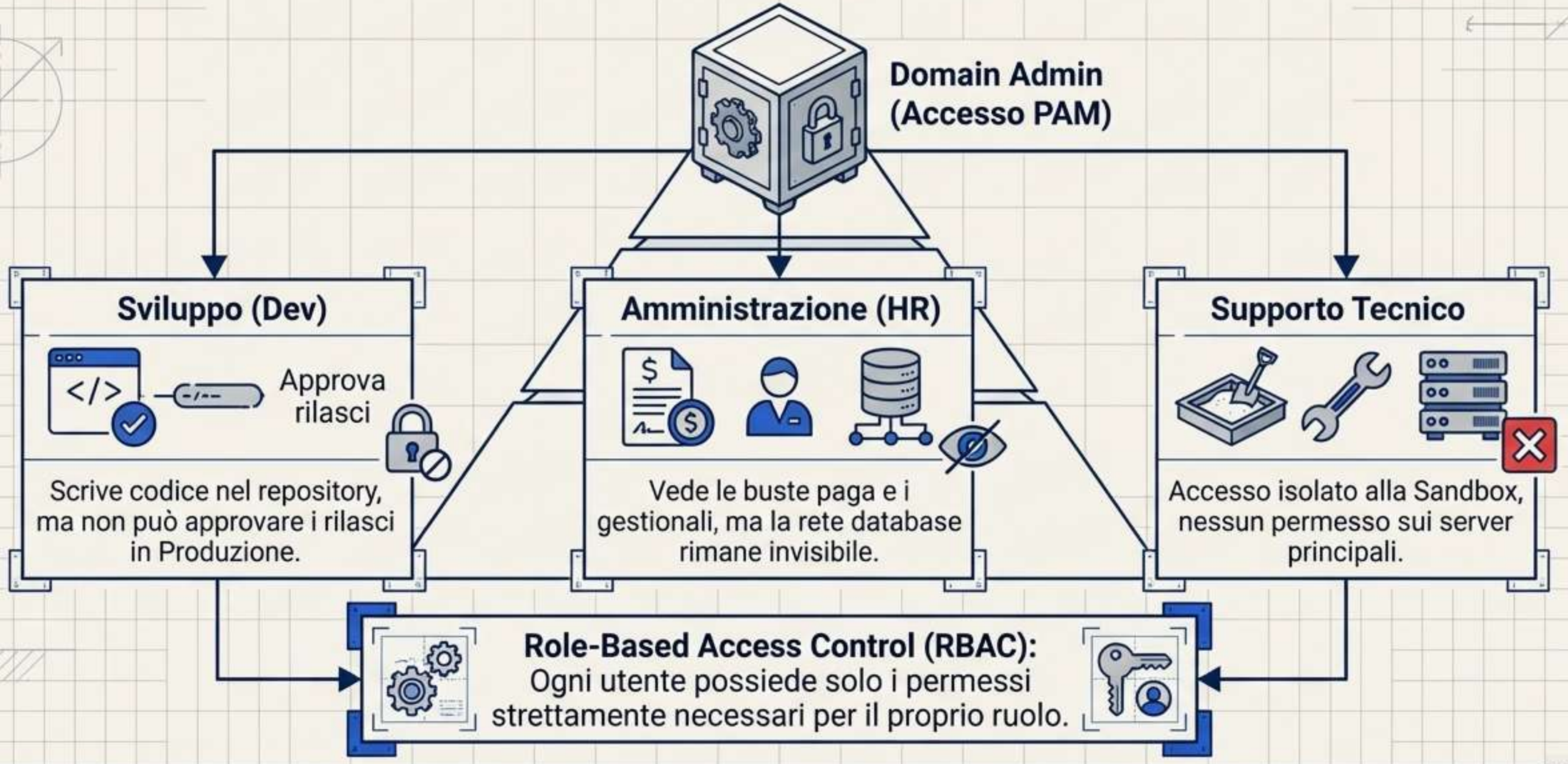


Agenti DLP: Blocco del trasferimento non autorizzato di codice su USB o cloud personali (Dropbox). Applicazione di Watermarking per tracciare i leak.

NotebookLM

Fase 4: Identity & Access Management (IAM)

Il **Principio del Minimo Privilegio (PoLP):** Eliminazione degli account **Generic** e **Admin** condivisi.

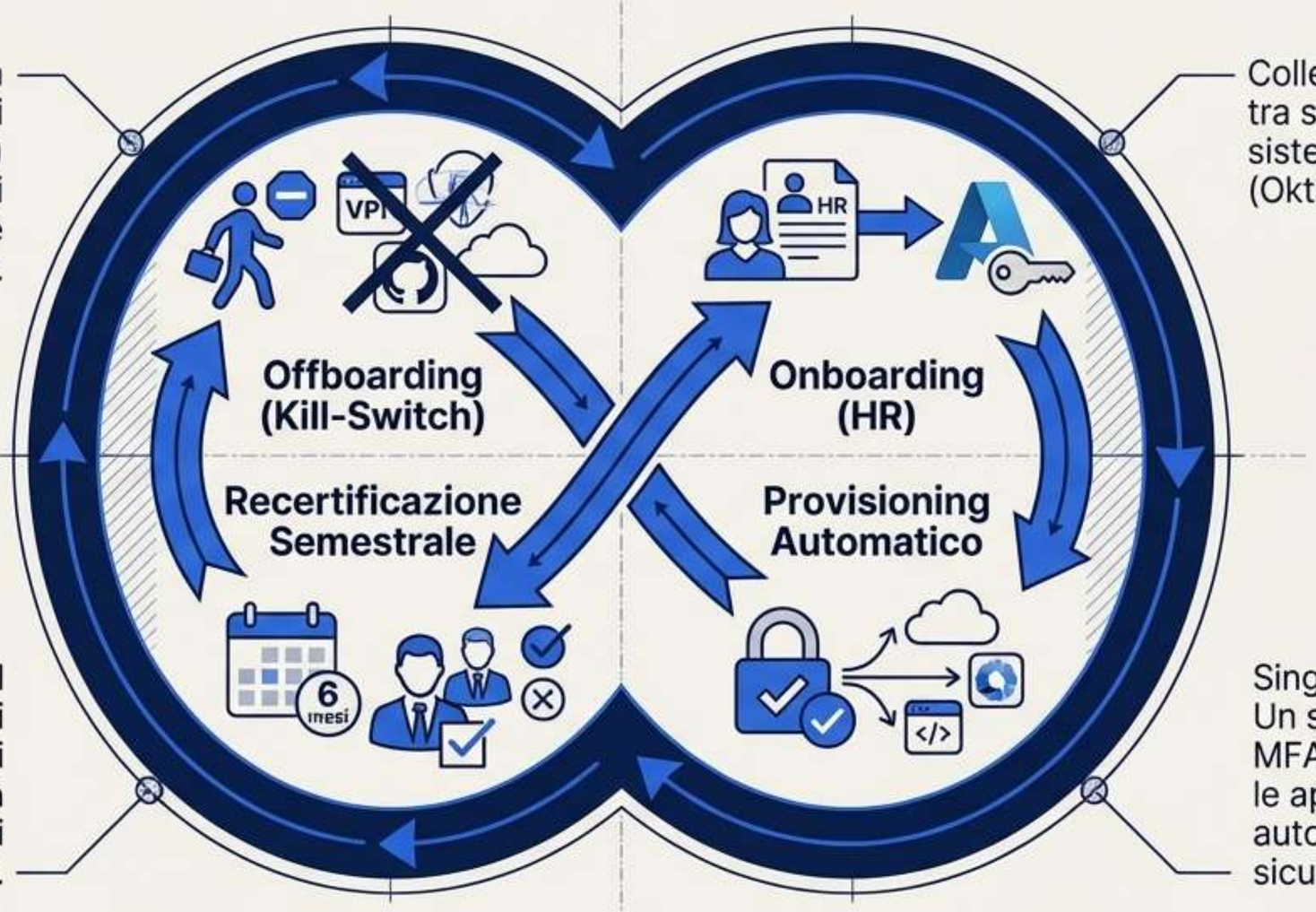


NotebookLM

Il Ciclo di Vita dell'Identità (Zero Account Fantasma)

Alla dimissione di un collaboratore, tutti gli accessi (VPN, GitHub) vengono revocati istantaneamente e automaticamente.

Collegamento diretto tra software HR e sistema di Identity (Okta/Entra ID).



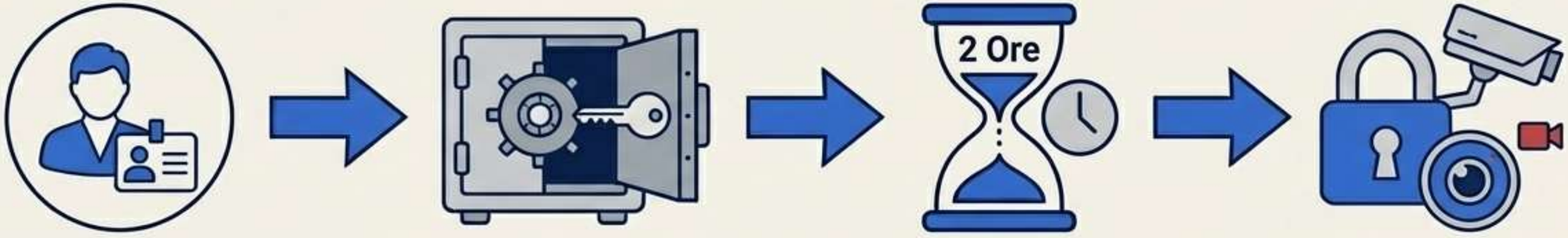
Combattere il "Privilege Creep". Ogni 6 mesi, i responsabili confermano la necessità degli accessi, altrimenti decadono.

Single Sign-On (SSO): Un singolo login MFA MFA mattutino sblocca le applicazioni autorizzate in totale sicurezza.

NotebookLM

Privileged Access e Accesso Temporaneo

Just-in-Time (JIT) Access Workflow



Richiesta Accesso

Approvazione Dinamica (CyberArk/BeyondTrust)

Permesso Temporaneo JIT

Sessione Registrata e Auto-Scadenza

Privileged Access Management (PAM)

Gli amministratori non possiedono password permanenti. Le prelevano da una cassaforte. La password ruota automaticamente (OTP).

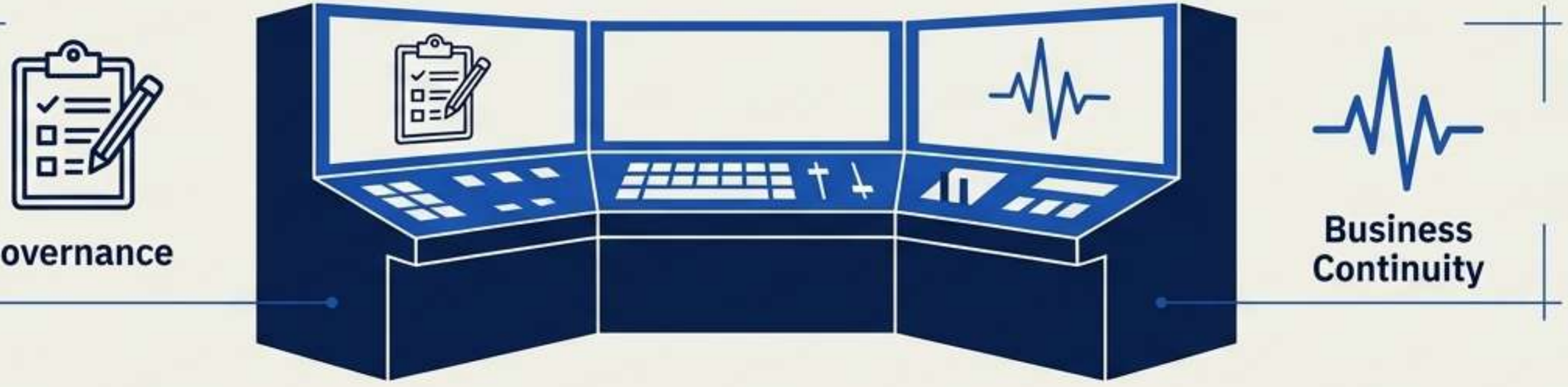
Just-in-Time (JIT)

Addio ai permessi Admin perpetui. I privilegi vengono concessi solo su richiesta e dotati di auto-scadenza (es. durata massima 2 ore).

NotebookLM

Fase 5: Governance e Business Continuity

Trasformare la sicurezza da una somma di strumenti in un processo aziendale vivo e continuo. **Garantire la sopravvivenza del business** anche nello scenario peggiore.



Business Continuity & Disaster Recovery (BCDR)

Backup Architetturali (Immutabilità)

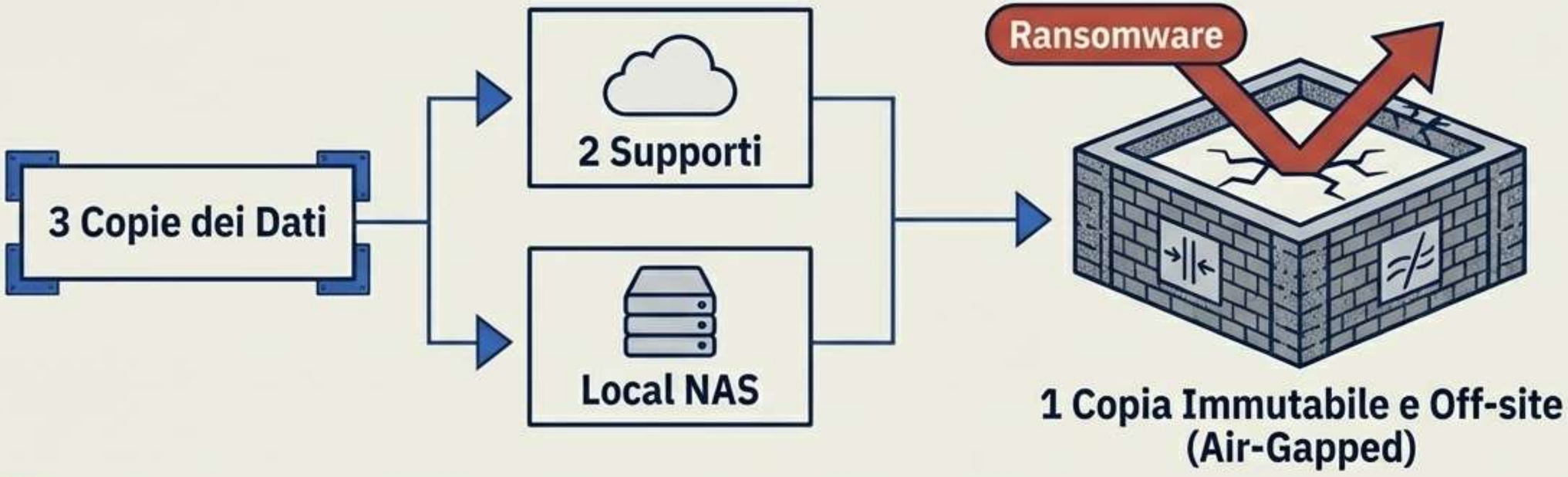
Cultura Aziendale (Human Firewall)

NotebookLM

Il Motore di Resilienza: Backup 3-2-1 e Metriche

RTO: 4 Hrs
Recovery Time Objective:
Riavvio operativo massimo

RPO: 1 Hr
Recovery Point Objective:
Perdita dati massima accettabile



Test Semestrali: Simulazioni regolari di perdita totale per verificare l'effettiva ripristinabilità. Se non lo testi, il backup non esiste.

NotebookLM

The Human Firewall & Incident Response

Formazione Attiva

Simulazioni di phishing periodiche. In caso di errore, micro-formazione immediata (5 minuti). Cultura della segnalazione tramite security@technosoft.it.

Incident Response Team (IRT)

Gruppo pronto al Minuto 0 per isolare la rete, preservare le prove forensi e gestire le comunicazioni GDPR. Vulnerability Assessment eseguiti mensilmente.

Vantaggio Competitivo

Estendere gli standard ai fornitori terzi e iniziare il percorso di certificazione ISO 27001 per eccellere nelle gare d'appalto.

NotebookLM

Roadmap Esecutiva: Tabella di Marcia di TechnoSoft

Priorità Temporale	Azione Chiave & Fase	Risultato di Business
Immediato	**MFA (Duo) + Password Policy** (Fase 1)	Blocco del 99% dei furti di account.
Breve Termine	**Reti VLAN Segmentate + EDR** (Fasi 1 e 2)	Isolamento delle minacce (Contenimento) e blocco ransomware.
Medio Termine	**Crittografia AES-256 + MDM + IAM** (Fasi 3 e 4)	Protezione totale del codice sorgente, dei dati in transito e dei laptop remoti.
Lungo Termine	**Formazione Utenti + BCDR/Backup Immutabili** (Fase 5)	Azienda pienamente resiliente, conforme e in grado di ripartire in 4 ore post-disastro.

NotebookLM